

Séance 8

DNS Spoofing/DNS Cache Poisoning

L'objectif du jour est de comprendre comment une attaque de type DNS Spoofing peut-être mise en oeuvre. Pour ce faire nous allons 1) créer un nouveau site sur le serveur que nous avons utilisé dans les séances précédente 2) configurer le serveur DNS pour que le site généré soit associé à un nom de domaine spécifique et 3) mettre en oeuvre cette attaque au niveau de l'attaquant.

Note 1 : Lorsque des commandes nécessitant des privilèges administrateurs seront utilisées, il sera nécessaire d'utiliser la commande *sudo* sous Debian GNU/Linux et *doas* sous OpenBSD.

Note 2 : Pour mettre ServMutilidae en FR : *sudo loadkeys fr*

Note 3 : Sur les dernières versions de VirtualBox, il peut être nécessaire de réaliser une étape de configuration pour que l'ensemble des adresses IP puissent être utilisées (et vboxnet1 créé). L'étape en question consiste à créer un fichier *"/etc/vbox/networks.conf"* contenant *"* 0.0.0.0/0 :::0"* et à relancer VirtualBox. Pour en savoir plus : https://www.virtualbox.org/manual/ch06.html#network_hostonly

A. Configuration du service Web

Répondez aux questions suivantes :

- Q1. Quel est le rôle d'un serveur DNS ?
- Q2. En quoi consiste une attaque de type DNS Spoofing (également nommée DNS cache poisoning) ?
- Q3. Quelles peuvent en être les conséquences ?
- Q4. Quels exemples d'attaques ayant réellement été exécutés pouvez vous donner ?

(Sources pertinentes :

<https://inetdoc.net/guides/tutoriel-secu/tutoriel.securite.attaquesprotocoles.dns.html> &

<https://www.proofpoint.com/fr/threat-reference/dns-spoofing> &

<https://www.bleepingcomputer.com/news/security/magintdns-attacks-exploit-weak-checks-for-dns-cache-poisoning/> & <https://kinsta.com/fr/blog/dns-poisoning/>)

Durant cette séance, nous considérerons que la victime (client légitime sous debian 10 - machine virtuelle DebClient 2/sous Kali en fonction de votre déploiement) souhaite se rendre sur le site www.local.sio.fr, hébergé par le serveur *srvm.local.sio.fr* (machine virtuelle ServMutilidae 2 déjà utilisée dans les sessions précédentes).

Actuellement le site www.local.sio.fr n'existe pas, le service web du serveur *srvm.local.sio.fr* est à configurer. et c'est ce que nous allons commencer à faire ici.

La première étape consiste à créer ce site Web au niveau du serveur qui s'appuie sur Apache. Celui-ci sera nommé site-victime. Pour qu'il puisse être rendu accessible par des clients extérieurs, nous allons devant :

- Créer un dossier "*site-victime*" dans le dossier `/var/www` utilisé comme emplacement par défaut pour héberger les fichiers des sites web dans le serveur
- Créez à minima un fichier "`index.html`" dans ce dossier qui correspondra à la page Home du site Web. Celle-ci peut contenir tout type de contenu, par exemple "Bienvenu sur notre site Web Victime"
- Nous allons maintenant ajouter un fichier site-victime dans `/etc/apache2/sites-available`, le dossier utilisé par Apache pour gérer les sites disponibles sur le serveur. Vous pouvez simplement effectuer une copie du fichier default existant en modifiant à l'intérieur de ce fichier le dossier racine (`/var/www/site-victime`)
- Une fois ce fichier créé nous allons vouloir l'ajouter à la configuration de Apache2, pour ce faire, nous pouvons utiliser la commande suivante : `a2ensite site-victime`
- La dernière étape consiste à recharger le service apache2 afin que ces modifications soient prises en compte : `/etc/init.d/apache2 reload`

Une fois ces différentes étapes réalisées, vous devriez être en mesure de tester l'accès au site à partir du navigateur du client en utilisant l'adresse IP du serveur web. (@IP/site-victime)

Q5. Par une capture d'écran, prouvez que cela fonctionne bien.

B. Configuration du service DNS

Nous souhaitons à présent, pour montrer le principe d'une attaque DNS Spoofing, que ce site web puisse être joignable via l'URL suivante : <http://www.local.sio.fr/site-victime>

L'idée va être de configurer le serveur DNS pour déclarer le nom pleinement qualifié www.local.sio.fr. Ceci a une signification simple. De base notre serveur est identifié comme `srvm.local.sio.fr` (associé à l'IP du serveur) et plutôt que d'utiliser systématiquement cela, nous souhaitons mettre en place un acronyme `www`. Le sous-domaine `www` fera donc office d'alias pour le nom de domaine `srvm.local.sio.fr`. En entrant donc www.local.sio.fr, cela voudra donc dire "Renvoyez moi sur le serveur Apache2 nommé `local.sio.fr` situé sur l'IP associé à `srvm.local.sio.fr`".

Ceci nous permet donc d'entrevoir ce que devra par la suite faire l'attaque DNS : se faire passer `srvm.local.sio.fr`.

- Pour réaliser cette configuration, vous avez simplement à entrer la ligne suivante dans le fichier `/var/named/db.local.sio.fr` (NE PAS OUBLIER LE "." à la fin) :
`www IN CNAME srvm.local.sio.fr.`

Celle-ci signifie simplement que toute demande destinée à WWW via internet sera redirigée vers le serveur `srvm.local.sio.fr`.

- Redémarrer ensuite le service bind9 : `sudo /etc/init.d/bind9 restart`

Il vous reste maintenant à prouver que ce que vous venez de mettre en place fonctionne bien. Pour ce faire, vous pouvez 1) utiliser une commande nslookup à partir du client pour vérifier et valider votre configuration. ⇒ nslookup www.local.sio.fr et 2) accéder à cette page via un navigateur du client.

Q6. Prouvez par des captures d'écran que ces deux opérations fonctionnent.

C. Réalisation de l'attaque

Q7. D'après le contexte présenté dans les sections A et B, quel va être l'objectif de la machine pirate sous Kali ?

La première étape à son niveau va donc être de créer son propre site web, vers lequel renverra le serveur DNS une fois que son comportement aura été altéré.

Un serveur Apache2 est également disponible sur la machine Kali de l'attaquant. Il va donc vous falloir réaliser les mêmes étapes que du côté du serveur Mutillidae pour générer chez l'attaquant un site Web qui pourra être accessible depuis l'extérieur.

- Réalisez donc les mêmes étapes que précédemment.
 - Note : Faites attention, le dossier utilisé ici comme emplacement par défaut n'est pas /var/www mais /var/www/html. C'est donc dans ce second dossier que vous devriez ici placer votre dossier. Vous pouvez mettre un contenu différent à votre page d'accueil, ce qui vous permettra de montrer que l'attaque fonctionne bien.
- Testez l'accès au site pirate à partir du navigateur du client sous debian (machine virtuelle DebClient 2) en utilisant l'adresse IP de l'attaquant.

Q8. Prouvez par une capture d'écran que cela fonctionne bien.

D. Configuration du DNS Spoofing

Pour configurer le DNS SPOOFING via l'outil Ettercap (déjà installé sur Kali) il faut modifier les fichiers /etc/ettercap/etter.conf et /etc/ettercap/etter.dns.

- Dans /etc/ettercap/etter.conf, vous devez :
 - modifier les valeurs de ec_uid et ec_gid à 0 pour permettre un fonctionnement via le compte « root » ;
 - décommenter les 4 lignes « iptables » (lignes 179, 180, 183 et 184) pour activer les redirections de trames (ie similaire à ce qu'on a vu dans les sessions précédentes : ceci permettra à l'attaquant de se faire passer pour la passerelle et de retransmettre le contenu).

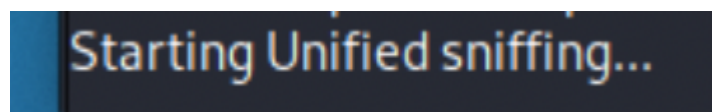
- Dans /etc/ettercap/etter.dns ,vous devez ajouter la section suivante :
local.sio.fr A @IP-ATTAQUANT (le nom de domaine principal pour lequel cette entrée est configurée => on redirige vers l'attaquant)
*.local.sio.fr A @IP-ATTAQUANT (on redirige également l'ensemble des sous domaines)
www.local.sio.fr PTR @IP-ATTAQUANT (mapper www vers l'IP de l'attaquant => On ne redirige plus vers le serveur !)

E. Configuration d'un ARP poisoning via ettercap

La prochaine étape consiste à effectuer une attaque MITM avec Ettercap. Cela a déjà été réalisé durant une des précédentes sessions en utilisant les lignes de commande. Durant cette séance, nous allons utiliser la version graphique de Ettercap.

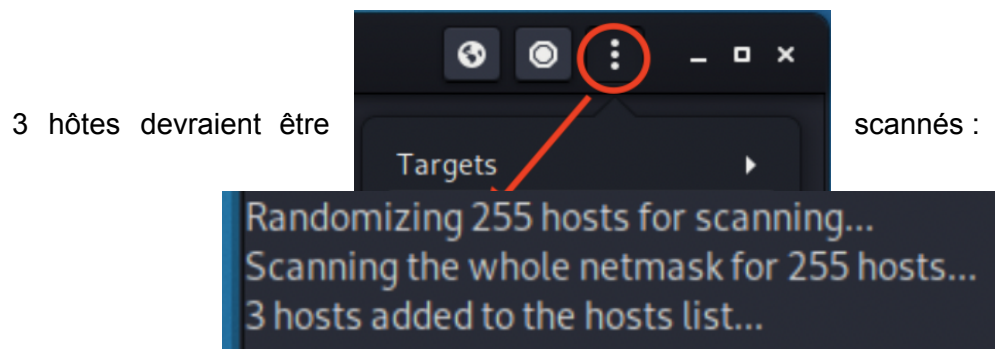
Q9. Rappelez en quoi consiste une attaque ARP POISONING (ou ARP SPOOFING).

- Lancez l'outil ettercap-graphical et vérifiez que l'interface d'écoute est bien eth0 :



Vous devez obtenir l'affichage suivant :

- Scannez le réseau afin de découvrir les hôtes disponibles. Pour cela, il faut cliquer sur le sous-menu « Scan for hosts » du menu « Hosts ».

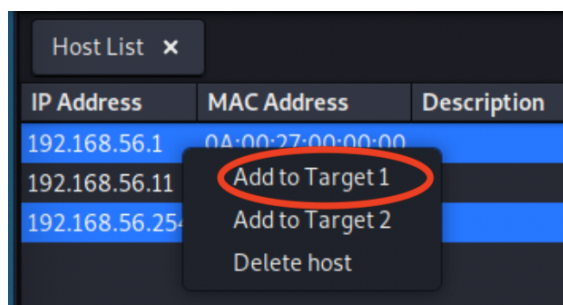


- Pour afficher la liste des hôtes, il faut cliquer sur le sous-menu « Host List » du menu « Hosts » :

Host List ✕		
IP Address	MAC Address	Description
192.168.56.1	0A:00:27:00:00:00	
192.168.56.11	08:00:27:16:6E:AA	
192.168.56.254	08:00:27:7D:43:66	

- Configurez les cibles. Deux cibles (« target ») doivent être définies :
 - la première correspond à la machine victime (192.168.56.1) ;
 - la seconde correspond à la passerelle (192.168.56.254). C'est cette sélection qui permettra de réaliser le positionnement MITM. La passerelle correspond au routeur OpenBSD (machine virtuelle RouteurOpenBSD 2).

Pour cela, il faut sélectionner les 2 hôtes concernés, faire un clique droit et choisir « Add to Target1 » :



=>

Host 192.168.56.254 added to TARGET1
Host 192.168.56.1 added to TARGET1

- Lancez l'ARP Poisoning (empoisonnement de cache ARP). Pour cela, il faut cliquer sur le sous-menu « ARP Poisoning » du sous menu « Mitm » (icône « planète terre » en haut à droite), vérifier que l'option « Sniff remote connections » est activée et validez.

Vous devriez obtenir un affichage du type :

```
ARP poisoning victims:

GROUP 1 : 192.168.56.254 08:00:27:7D:43:66
GROUP 1 : 192.168.56.1 0A:00:27:00:00:00

GROUP 2 : ANY (all the hosts in the list)
```

- Le plugin « chk_poison » permet de vérifier le succès de l'empoisonnement. Pour cela, il faut cliquer sur le sous menu « Manage the plugins » du menu « Plugins ». Un double clic sur le plugin doit afficher un message confirmant le succès de l'opération :

Host List ✕		Plugins ✕	
Name	Version	Info	
arp_cop	1.1	Report suspicious ARP activity	
autoadd	1.2	Automatically add new victims in the target range	
chk_poison	1.1	Check if the poisoning had success	
dns_spoof	1.3	Sends spoofed dns replies	

- Vous devriez obtenir un affichage du type :

```
Activating chk_poison plugin...
chk_poison: Checking poisoning status...
chk_poison: Poisoning process successful!
```

- Vérifiez sur le client que la machine pirate est bien la passerelle du trafic (ip neigh show).

F. Lancement de l'attaque DNS SPOOFING

Maintenant que l'attaque MITM est opérationnelle, vous pouvez lancer le DNS SPOOFING. Pour cela, il faut double cliquer sur le plugin « dns_spoof ».

- Lancez le plugin « dns_spoof ».

À partir de maintenant, lorsque la victime va consulter le site du Web (<http://www.local.sio.fr>), la requête devrait être automatiquement redirigée vers le site pirate, et des logs de ce type doivent s'afficher sur Ettercap :

```
Activating dns_spoof plugin...
dns_spoof: A [www.local.sio.fr] spoofed to [192.168.56.12] TTL [3600 s]
```

- Visitez, à partir du client, le site que nous venons de configurer et vérifiez que le site pirate s'affiche.

Q10. Prouvez par une capture d'écran que cela fonctionne bien

G. Proposition de contre-mesures

Q11. Proposez des contre-mesures pour éviter et pour limiter une telle attaque.

(Source : <https://kinsta.com/fr/blog/dns-poisoning/>)

Q12. Répondez aux questions suivantes :

- Quelles autres attaques peuvent être envisagées à l'encontre d'un serveur DNS ? (citez en un minimum de 3).
- Décrivez notamment le principe de l'attaque d'amplification DNS.

(Source : <https://www.akamai.com/fr/glossary/what-is-a-dns-amplification-attack> & <https://blog.nameshield.com/fr/2017/09/06/3-attaques-dns-plus-communes-combattre/>)

Q13. Comment la mise en place de solutions telles que l'Anycast et la redondance des serveurs peut-elle renforcer la résilience du DNS face aux attaques ?

(Source : <https://www.cloudflare.com/fr-fr/learning/dns/what-is-anycast-dns/>)